Thunderhead Labs

Security Assessment

December 4th, 2024 — Prepared by OtterSec

Nicholas R. Putra nicholas@osec.io

Robert Chen r@osec.io

Table of Contents

Executive Summary **2**

Overview 2

Key Findings 2

Scope **3**

Findings **4**

General Findings **5**

OS-THL-SUG-00 | Code Refactoring 6

OS-THL-SUG-01 | Code Maturity 7

Appendices

Vulnerability Rating Scale **8**

Procedure **9**

© 2024 Otter Audits LLC. All Rights Reserved.

01 — Executive Summary

Overview

Thunderhead Labs engaged OtterSec to assess the `stmove-contracts-eth` program. This assessment was conducted between November 27th and November 28th, 2024. For more information on our auditing methodology, refer to Appendix B.

Key Findings

We produced 2 findings throughout this audit engagement.

We recommended modifying the codebase to mitigate potential security issues and improve functionality (OS-THL-SUG-00) and made suggestions regarding inconsistencies in the codebase to ensure adherence to best development practices (OS-THL-SUG-01).

© 2024 Otter Audits LLC. All Rights Reserved.

02 — Scope

The source code was delivered to us in a Git repository at https://github.com/thunderhead-labs/stmove-contracts-eth. This audit was performed against commit 4a28edf.

A brief description of the program is as follows:

Name	Description
stmove-contracts-eth	The system employs a non-transferable, rebasing token mechanism to simulate APY growth by periodically increasing user balances. It includes a locking feature that enables users to deposit `MOVE` tokens in exchange for `fstMOVE`, which locks the `MOVE` tokens while acting as a placeholder to represent future staking rewards or allocations.

© 2024 Otter Audits LLC. All Rights Reserved.

03 — Findings

Overall, we reported 2 findings.

We split the findings into **vulnerabilities** and **general findings**. Vulnerabilities have an immediate impact and should be remediated as soon as possible. General findings do not have an immediate impact but will aid in mitigating future vulnerabilities.

Severity	Count
CRITICAL	0
HIGH	0
MEDIUM	0
LOW	0
INFO	2

© 2024 Otter Audits LLC. All Rights Reserved.

04 — General Findings

Here, we present a discussion of general findings during our audit. While these findings do not present an immediate security impact, they represent anti-patterns and may result in security issues in the future.

ID	Description
OS-THL-SUG-00	Recommendations for modifying the codebase to mitigate potential security issues and improve functionality.
OS-THL-SUG-01	Suggestions regarding inconsistencies in the codebase and ensuring adherence to coding best practices.

© 2024 Otter Audits LLC. All Rights Reserved.

Code Refactoring

OS-THL-SUG-00

Description

1. In `fstMOVE::rebaseByShareRate`, `nextShareRate_` is validated against the last recorded share rate. However, this may not accurately reflect the current state of the share rate, as it is dynamic and updates over time. Ensure to compare `nextShareRate_` against the current effective share rate (`currentRate`).

   >_ *src/token/fstMOVE.sol* SOLIDITY

   ```solidity
   function rebaseByShareRate(uint256 nextShareRate_, uint256 updateEnd_) external
       ↪  onlyRole(DEFAULT_ADMIN_ROLE) {
       if (nextShareRate_ < lastShareRate) revert NegativeRebaseNotAllowed();
       if (updateEnd_ < block.timestamp) revert UpdateMustBeInFuture()
       lastShareRate = shareRate();
       updateStart = block.timestamp;
       [...]
   }
   ```

2. `fstMOVE::_update` should explicitly verify that the `from` address is `address(0)` to ensure that only minting is allowed, and that `to` is not `address(0)` to prevent burning or invalid transfers. If these conditions are not met, the function should revert with an error.

Remediation

Incorporate the above-stated refactors.

© 2024 Otter Audits LLC. All Rights Reserved.

Code Maturity

OS-THL-SUG-01

Description

1. Emit `msg.sender` along with the old and new `moveAddress` in the `Redesignation` event to improve clarity.

   >_ *src/Lock.sol* SOLIDITY

   ```solidity
   function redesignate(bytes32 moveAddress) public {
       if (frozen) {
           revert LockPeriodEnded();
       }
       emit Redesignation(designated[msg.sender], moveAddress);
       designated[msg.sender] = moveAddress;
   }
   ```

2. `fstMOVE` still imports `forge-std` library, which is only used for testing and debugging purposes and is not meant to be in production code.

Remediation

Implement the above-mentioned suggestions.

© 2024 Otter Audits LLC. All Rights Reserved.

A — Vulnerability Rating Scale

We rated our findings according to the following scale. Vulnerabilities have immediate security implications. Informational findings may be found in the General Findings.

CRITICAL

Vulnerabilities that immediately result in a loss of user funds with minimal preconditions.

Examples:

- Misconfigured authority or access control validation.
- Improperly designed economic incentives leading to loss of funds.

HIGH

Vulnerabilities that may result in a loss of user funds but are potentially difficult to exploit.

Examples:

- Loss of funds requiring specific victim interactions.
- Exploitation involving high capital requirement with respect to payout.

MEDIUM

Vulnerabilities that may result in denial of service scenarios or degraded usability.

Examples:

- Computational limit exhaustion through malicious input.
- Forced exceptions in the normal user flow.

LOW

Low probability vulnerabilities, which are still exploitable but require extenuating circumstances or undue risk.

Examples:

- Oracle manipulation with large capital requirements and multiple transactions.

INFO

Best practices to mitigate future security risks. These are classified as general findings.

Examples:

- Explicit assertion of critical internal invariants.
- Improved input validation.

© 2024 Otter Audits LLC. All Rights Reserved.

B — Procedure

As part of our standard auditing procedure, we split our analysis into two main sections: design and implementation.

When auditing the design of a program, we aim to ensure that the overall economic architecture is sound in the context of an on-chain program. In other words, there is no way to steal funds or deny service, ignoring any chain-specific quirks. This usually requires a deep understanding of the program's internal interactions, potential game theory implications, and general on-chain execution primitives.

One example of a design vulnerability would be an on-chain oracle that could be manipulated by flash loans or large deposits. Such a design would generally be unsound regardless of which chain the oracle is deployed on.

On the other hand, auditing the program's implementation requires a deep understanding of the chain's execution model. While this varies from chain to chain, some common implementation vulnerabilities include reentrancy, account ownership issues, arithmetic overflows, and rounding bugs.

As a general rule of thumb, implementation vulnerabilities tend to be more "checklist" style. In contrast, design vulnerabilities require a strong understanding of the underlying system and the various interactions: both with the user and cross-program.

As we approach any new target, we strive to comprehensively understand the program first. In our audits, we always approach targets with a team of auditors. This allows us to share thoughts and collaborate, picking up on details that others may have missed.

While sometimes the line between design and implementation can be blurry, we hope this gives some insight into our auditing procedure and thought process.

© 2024 Otter Audits LLC. All Rights Reserved.